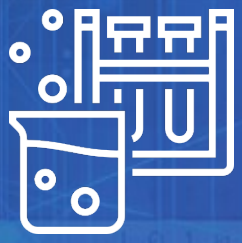
Lab Assignment & Solution



Copyright © 1996-2021 HackerU Ltd.
All Rights Reserved.

Cybersecurity Professional Program

Ethical Hacking

Web Application Security Fundamentals

EH-09-LS2

Intercept and Access

Note: Solutions for the instructor appear in a green colored box.

Lab Objective

Learn how to configure Burp Suite to work with the browser and intercept HTTP traffic for manipulation.

Lab Mission

Intercept network HTTP traffic and hack login credentials.

Lab Duration

30–45 minutes

Requirements

- Knowledge of Kali OS.
- Basic knowledge of networking.
- Basic knowledge of HTTP.
- Basic knowledge of Burp Suite.

Resources

- Environment & Tools
    - VirtualBox
        - Kali Linux
            - Burp Suite
            - Apache2
            - Browser
- Extra Lab Files
    - WebPage Folder

Textbook References

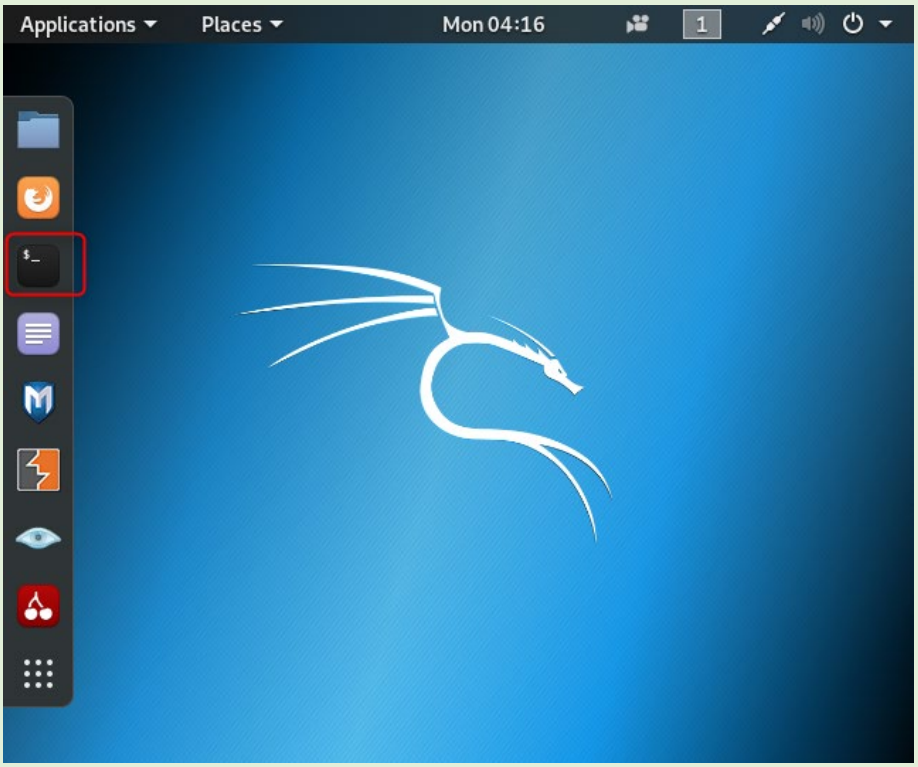
- Chapter 9: Web Application Security Fundamentals
    - Section 2: Burp Suite

Lab Task 1: Intercept HTTP Traffic

In this task, you will use Burp Suite to intercept communication between the browser and websites over the internet.

1. Start your Kali and pfSense machines.
2. Run Burp Suite. Ignore the message “Your JRE appears to be version 11.0.4 from Debian. Burp has not been fully tested on this platform and you may experience problems”.

Start a terminal session by clicking the terminal icon in the menu bar.



Type **burpsuite** and press Enter:

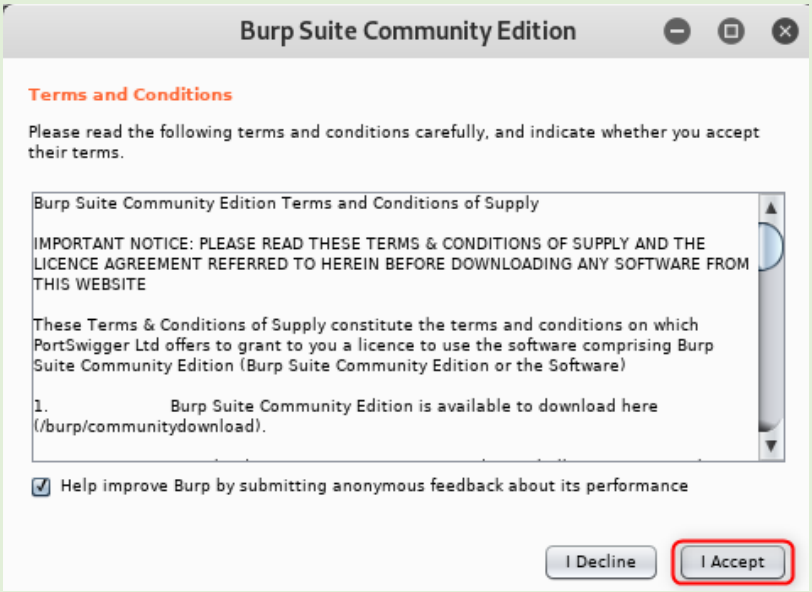
```
root@kali:~# burpsuite
Jan 18, 2021 7:21:51 AM java.util.prefs.FileSystemPreferences$1 run
INFO: Created user preferences directory.
Your JRE appears to be version 11.0.4 from Debian
Burp has not been fully tested on this platform and you may experience proble
ms.
```

Ignore the warning dialog and click OK.

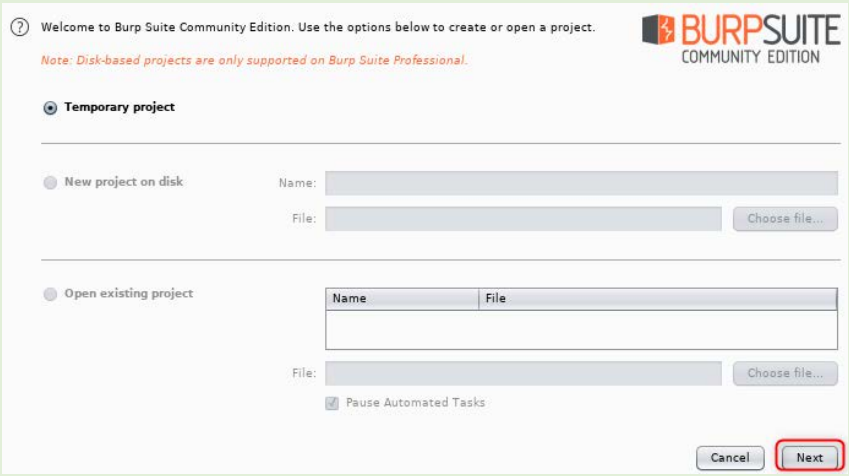


3 Start a new "Temporary project" using Burp Suite defaults and initiate proxy interception while browsing to google.com. Don't update Burp Suite.

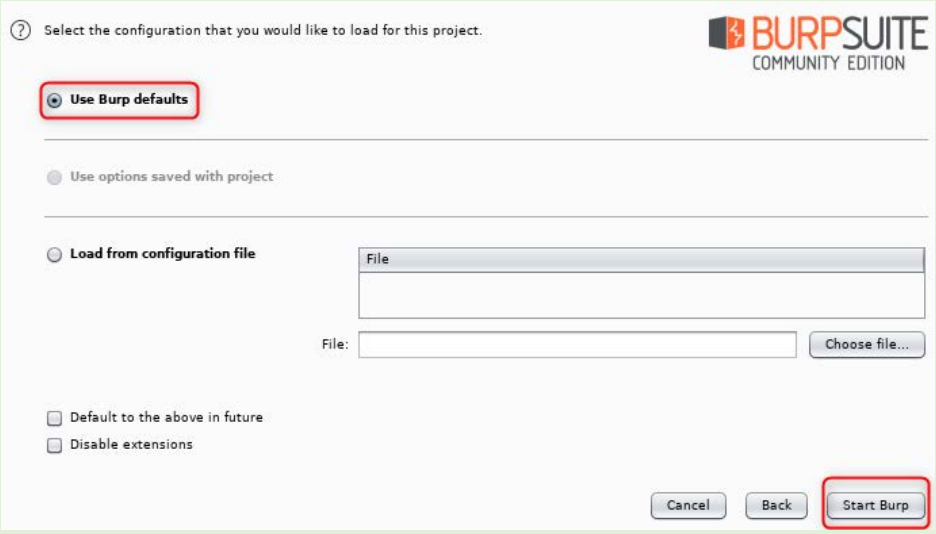
Wait for Burp Suite to start and accept the terms and conditions.



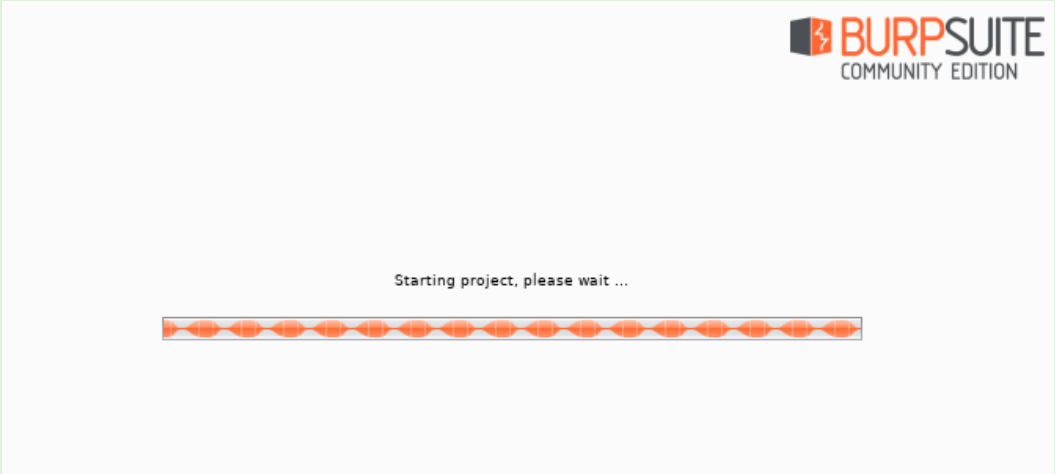
Select Temporary project and click Next.



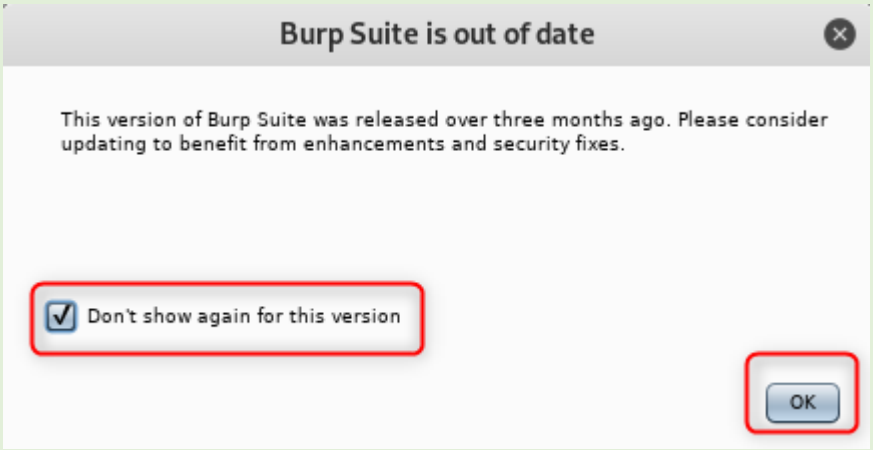
Select “Use Burp defaults” and click Start Burp.



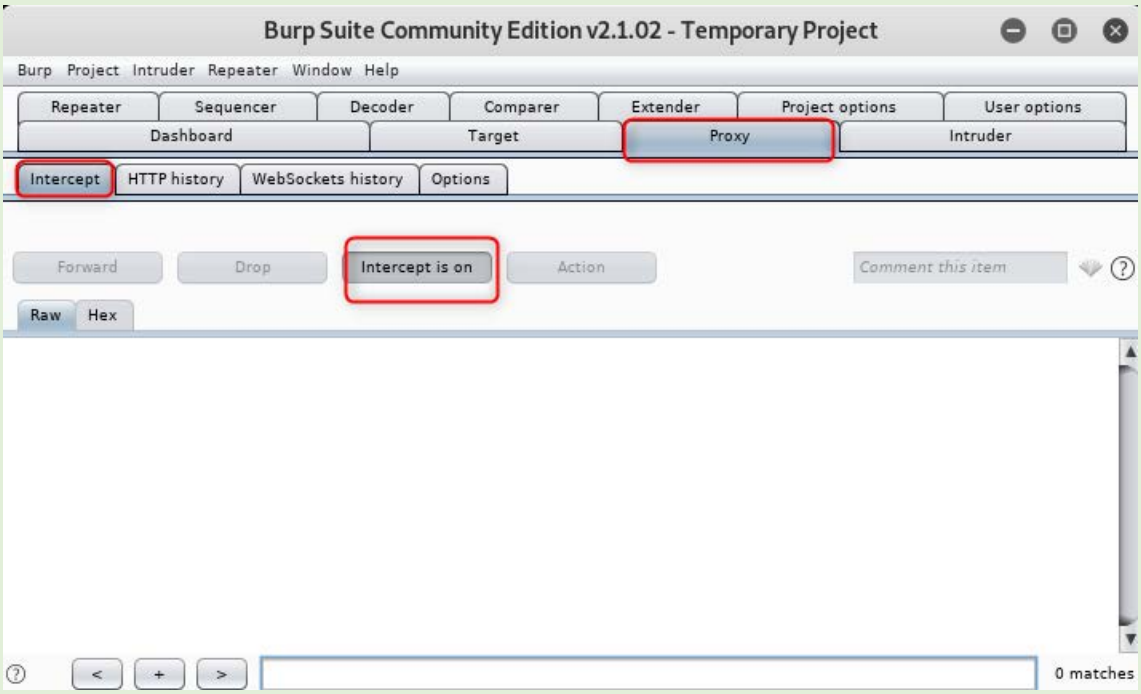
Wait for the project initialization to end.



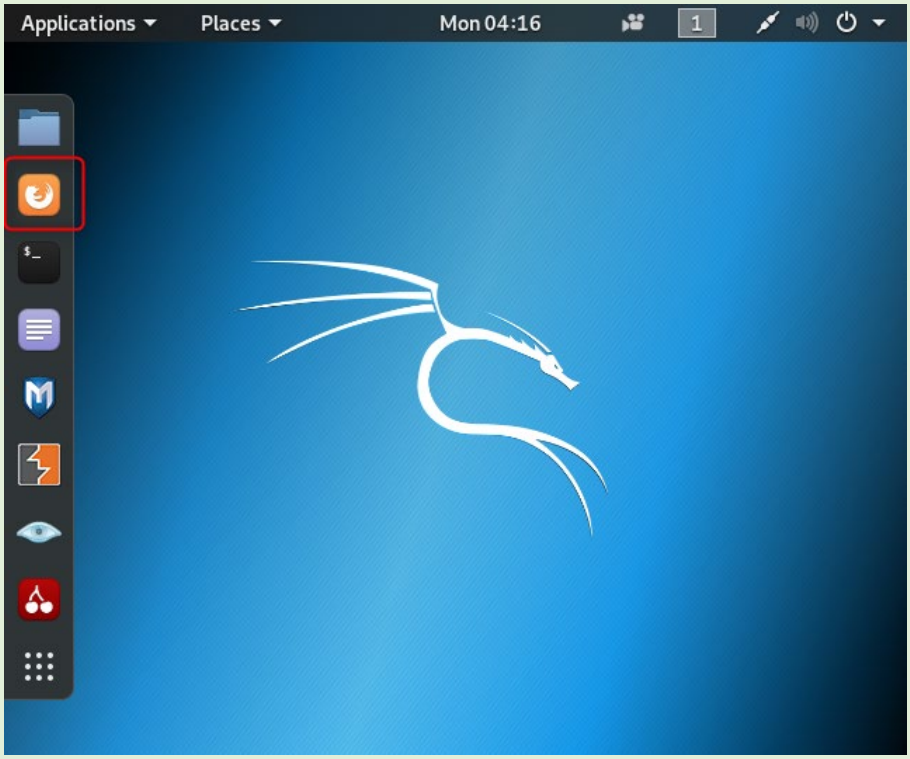
Ignore the out-of-date notification, make sure the option “Don’t show again for this version” is selected, and click OK.



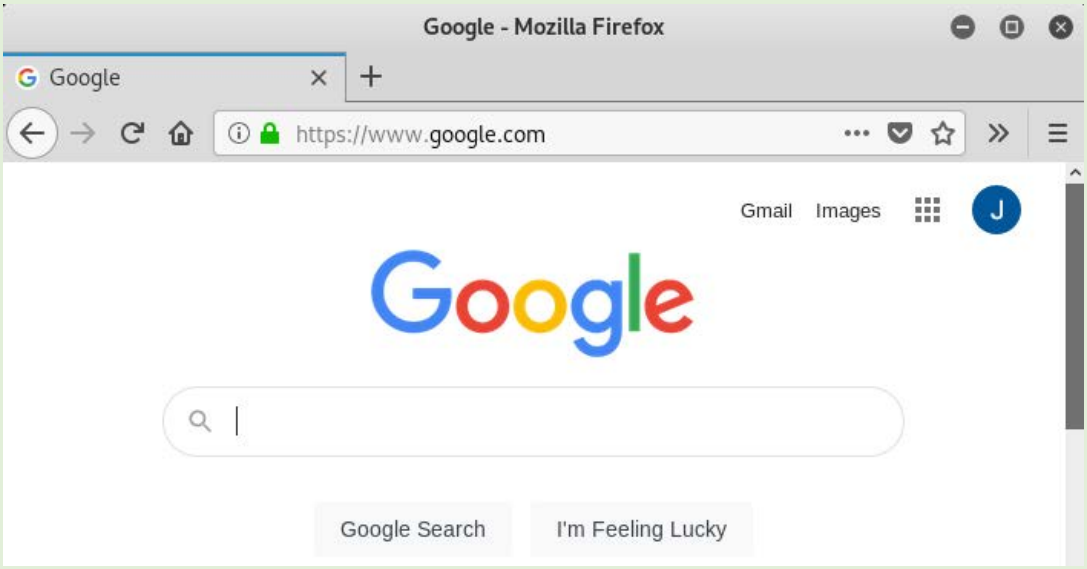
Switch to the proxy tab and make sure Intercept mode is on.



Open the browser by clicking the Firefox icon in the menu bar.

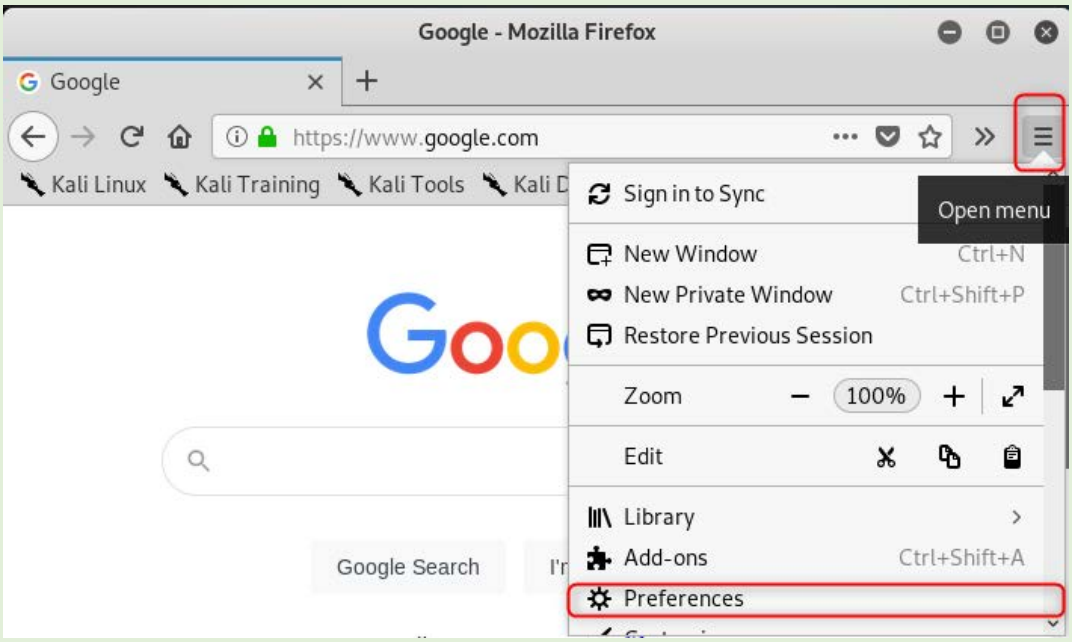


Type google.com in the URL address field to navigate to Google.

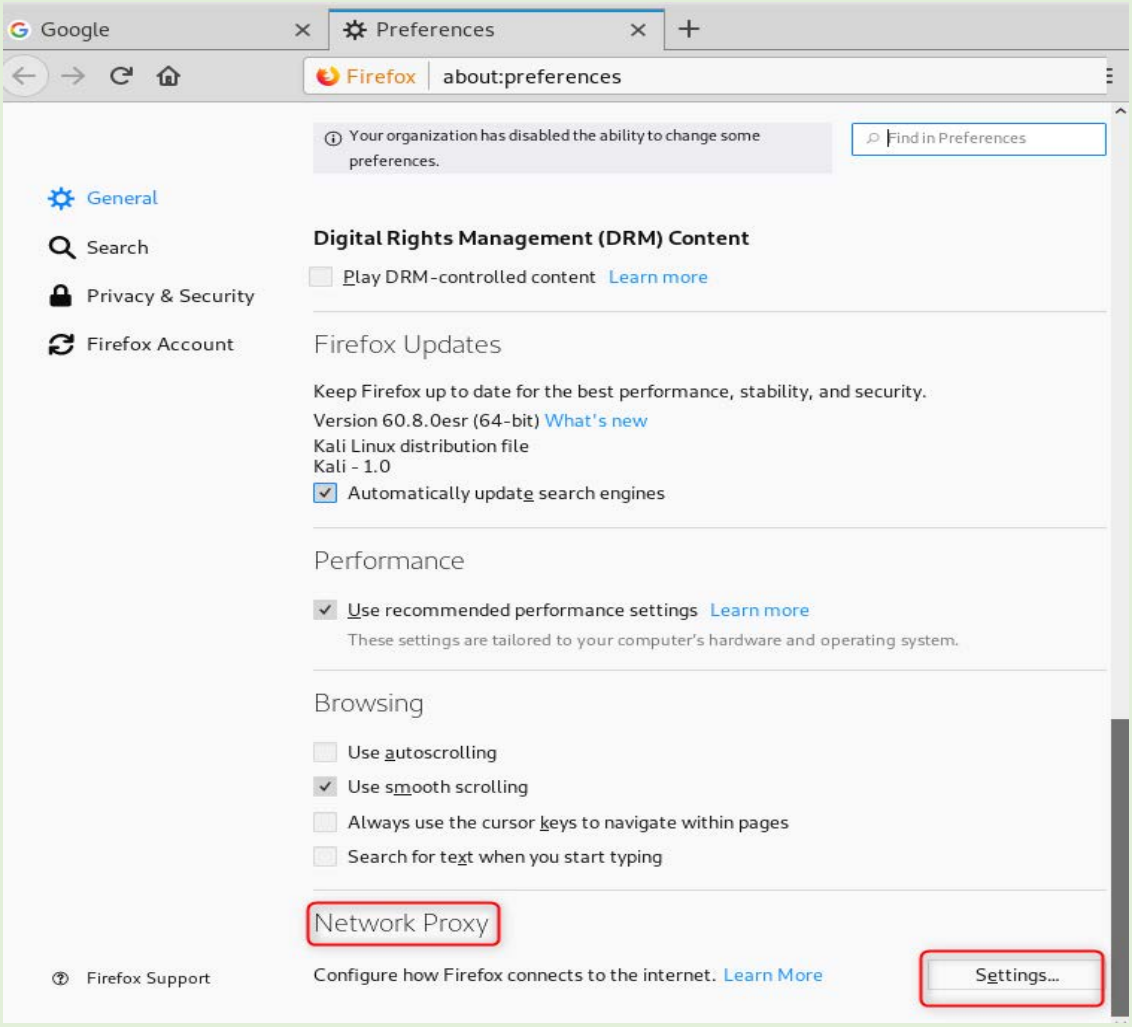


4 Note that the interception does not work. This happens because Firefox is not configured to use Burp as a proxy server. Proceed with configuring the proxy.

Click the menu icon to the right of the URL address field and select Preferences.

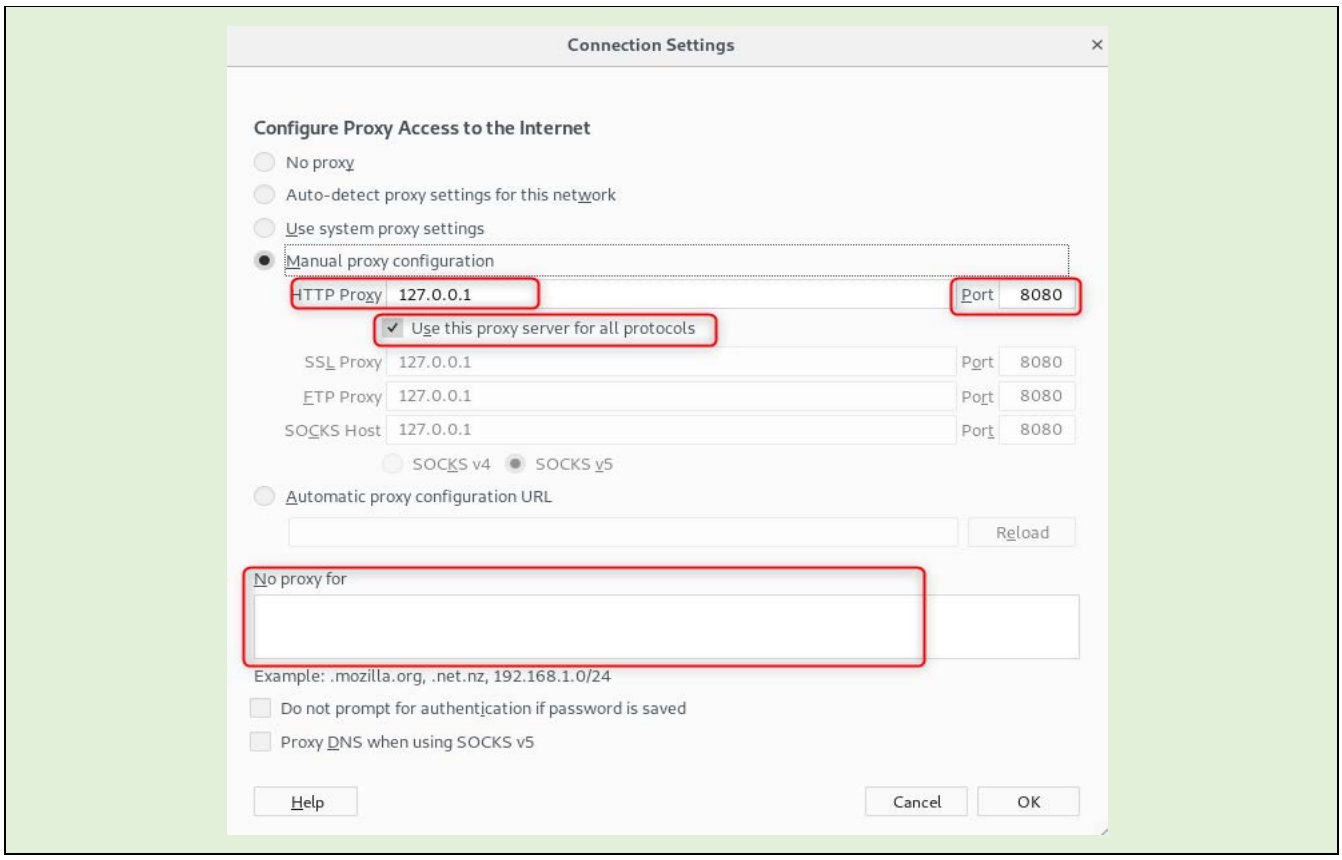


Scroll to the Network Proxy section at the bottom of the Preferences page, and click Settings.



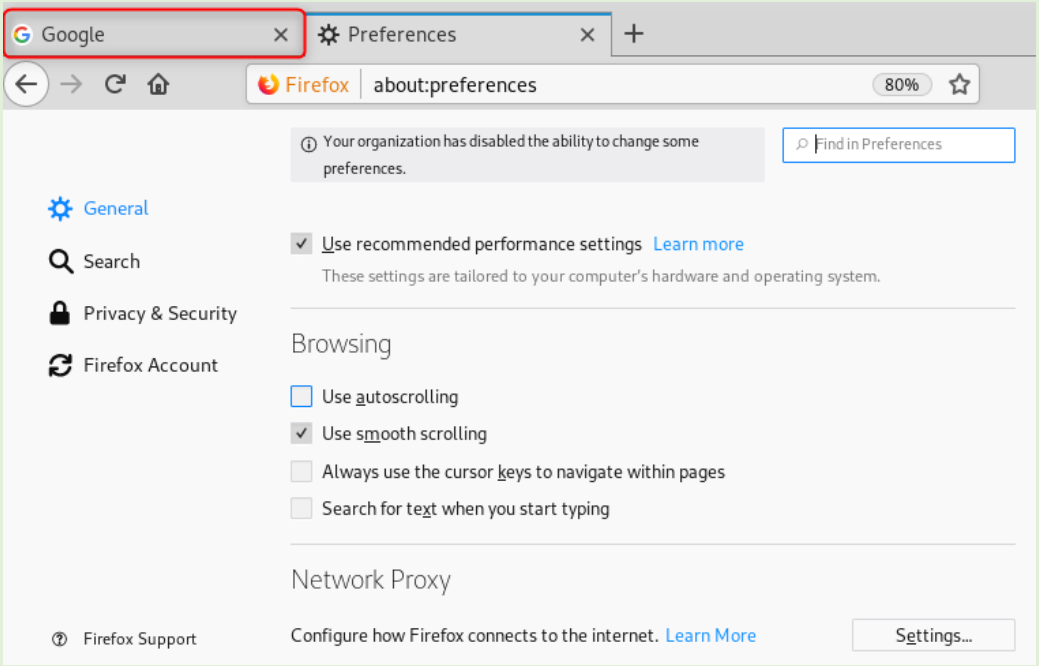
Select “Manual proxy configuration” and make sure “Use this proxy server for all protocols” is selected. Set the address 127.0.0.1 and port 8080.

Make sure the “No proxy for” specifications are empty and click OK.

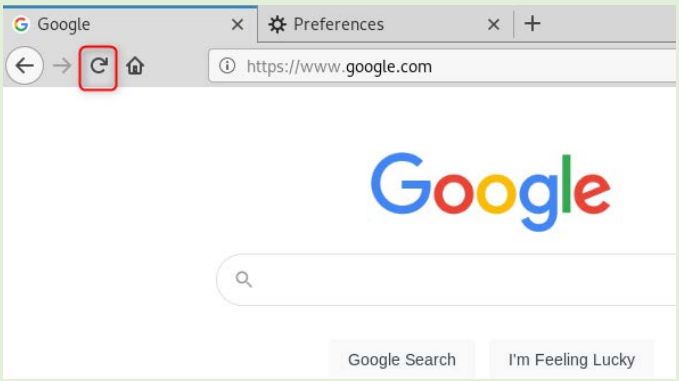

Connection Settings
Configure Proxy Access to the Internet
No proxy
Auto-detect proxy settings for this network
Use system proxy settings
Manual proxy configuration
HTTP Proxy 127.0.0.1
Port 8080
Use this proxy server for all protocols
SSL Proxy 127.0.0.1
Port 8080
FTP Proxy 127.0.0.1
Port 8080
SOCKS Host 127.0.0.1
Port 8080
SOCKS v4
SOCKS v5
Automatic proxy configuration URL
Reload
No proxy for
Example: .mozilla.org, .net.nz, 192.168.1.0/24
Do not prompt for authentication if password is saved
Proxy DNS when using SOCKS v5
Help
Cancel
OK

5 Browse to Google and note the unsecure connection warning. The warning appears because there is no certificate in use.

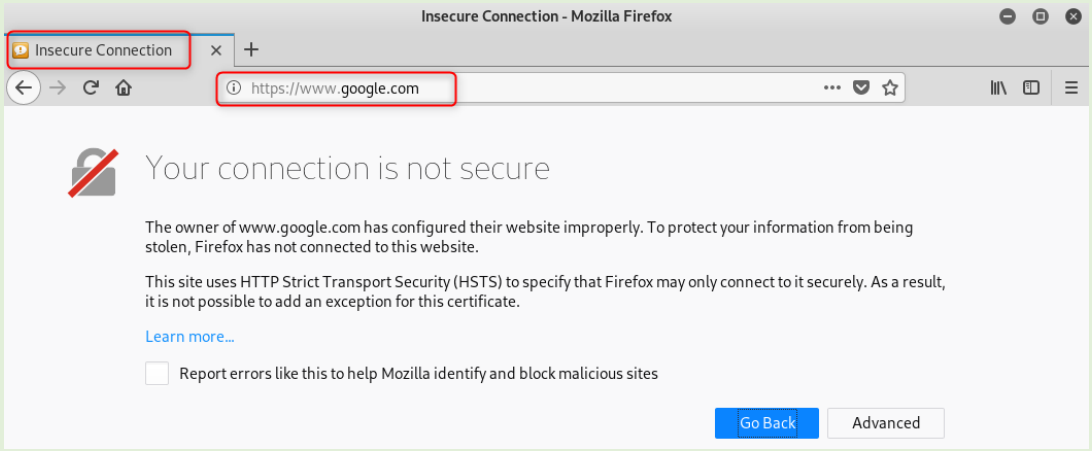
Switch back to the Google tab in Firefox.



Refresh the page.



An unsecure connection warning appears.



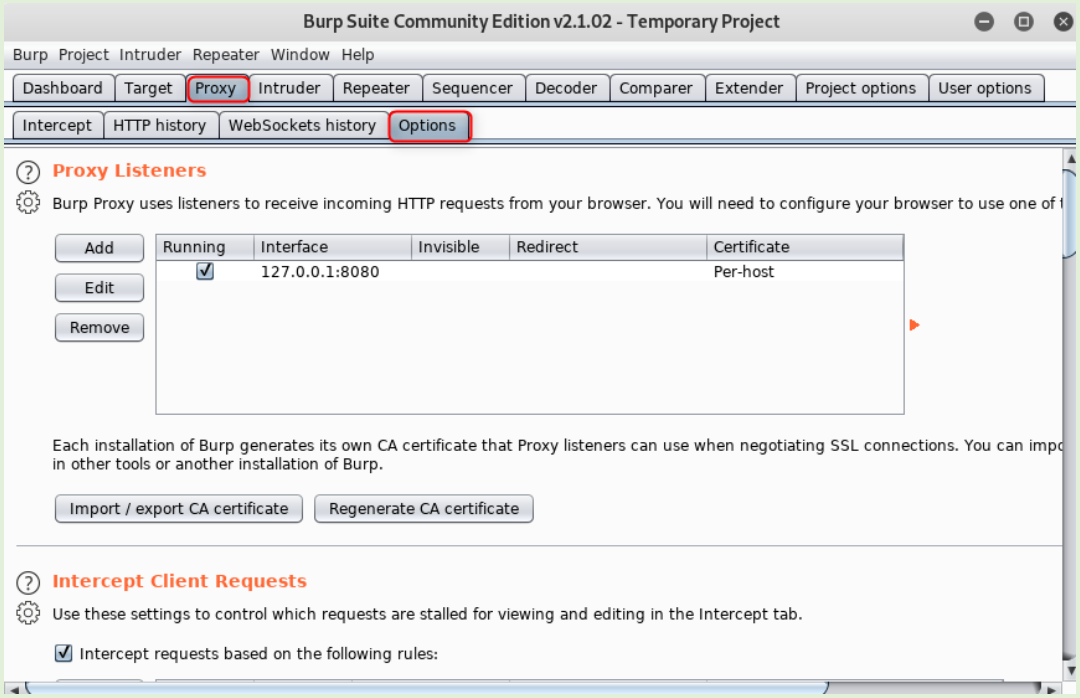
The warning means that there is no certificate in use.

Lab Task 2: Use a Burp Suite Certificate

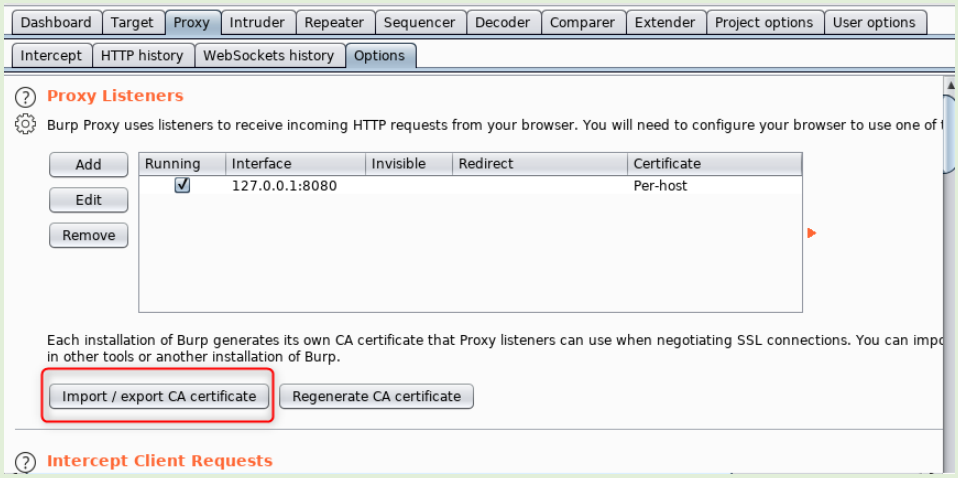
In this task, you will generate Burp's certificate and insert it in the Firefox browser.

1 From the proxy Options tab in Burp Suite, export a CA certificate in DER format and save it to your machine. Name the certificate "cert.crt".

Switch back to the Burp Suite screen.
Make sure that you are in the Proxy tab and switch to the Options tab.



Click "Import/ export CA certificate".

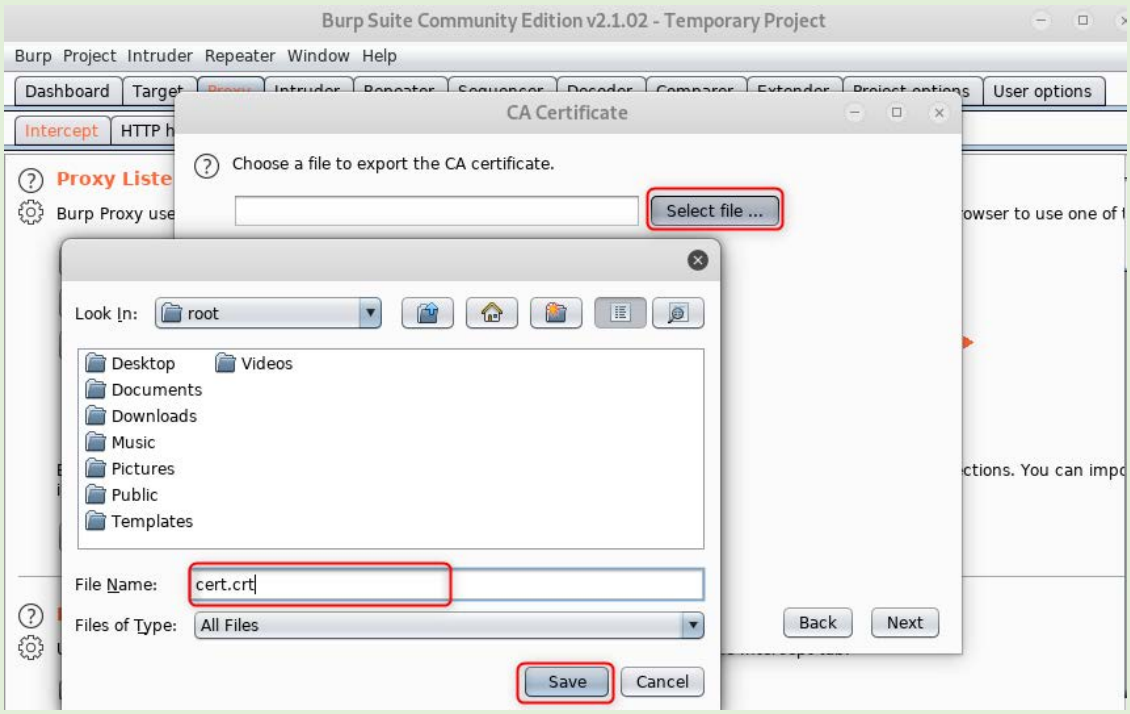


Under Export, select “Certificate in DER format”, and click Next.

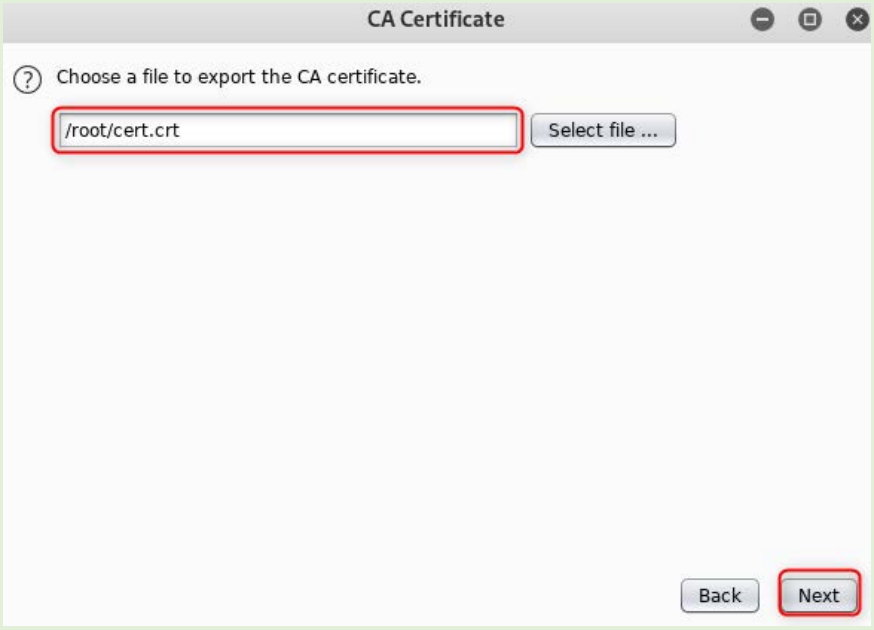


Click Select file.

In the File Name field, enter “cert.crt”, and click Save.



Click Next to save it to /root/.

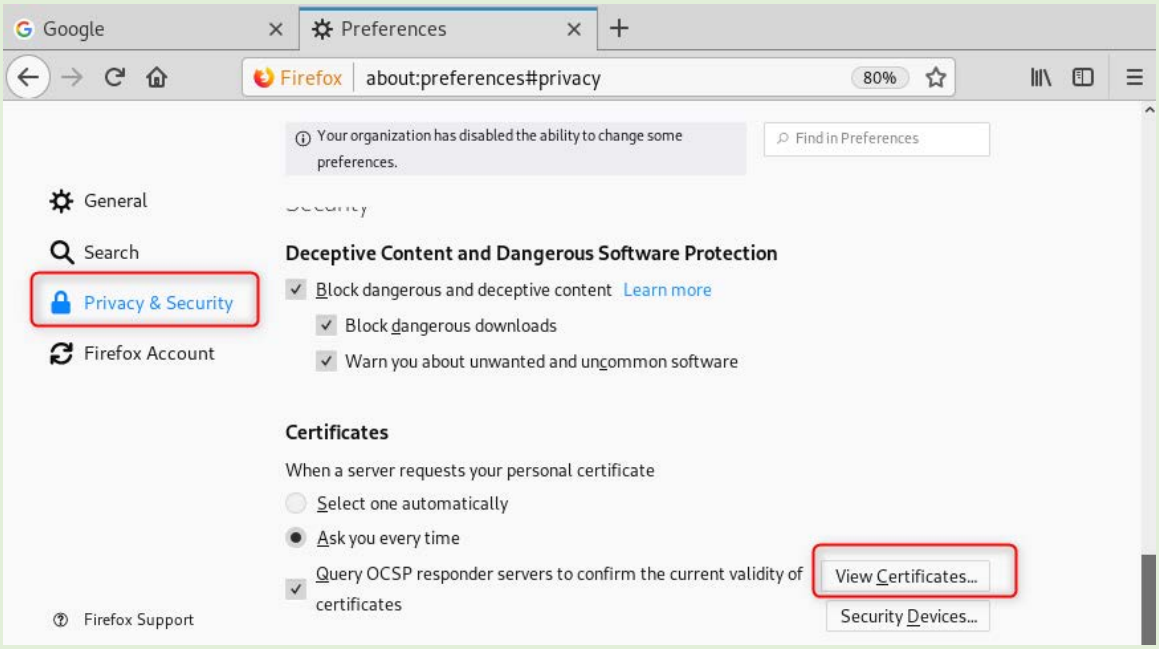


A message appears saying the certificate was exported successfully.

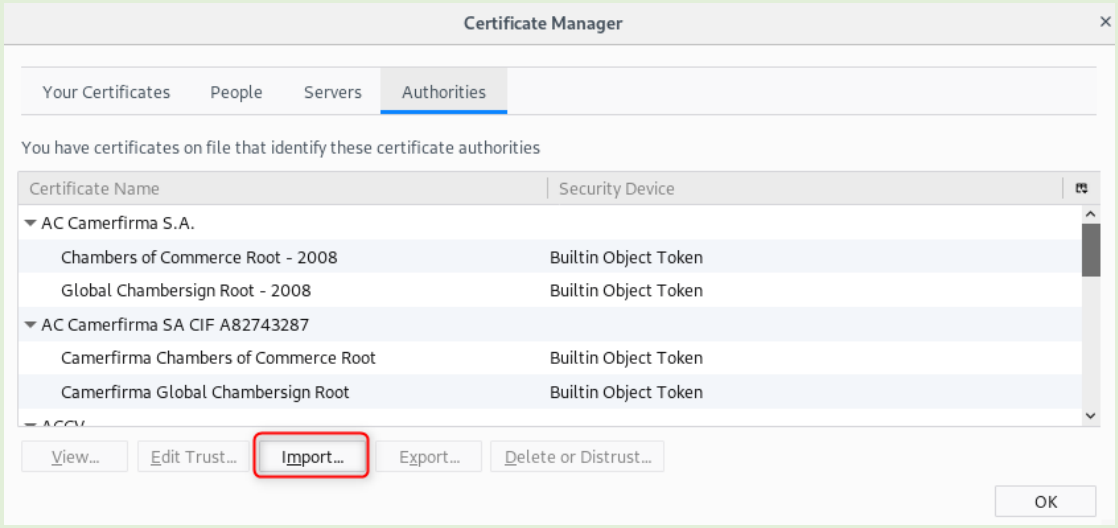


2 Apply the exported certificate to Firefox.

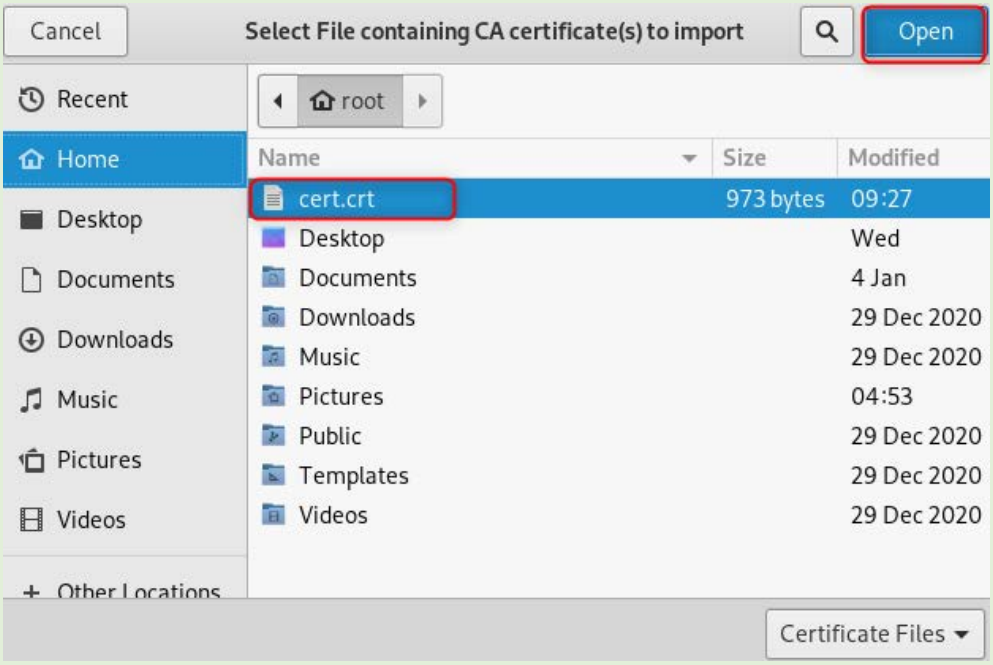
Switch back to Firefox and select the Preferences tab.
Select the “Privacy & Security” tab, scroll down to the Certificates area, and click View Certificates.



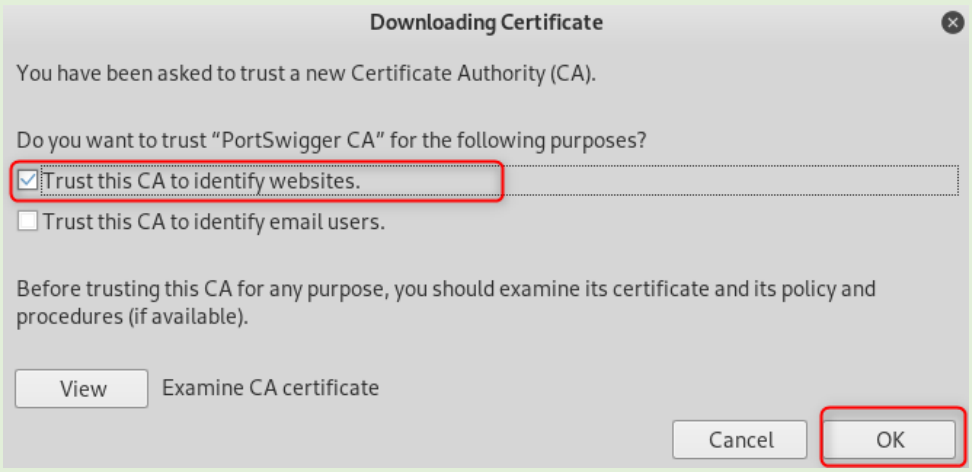
Click Import.



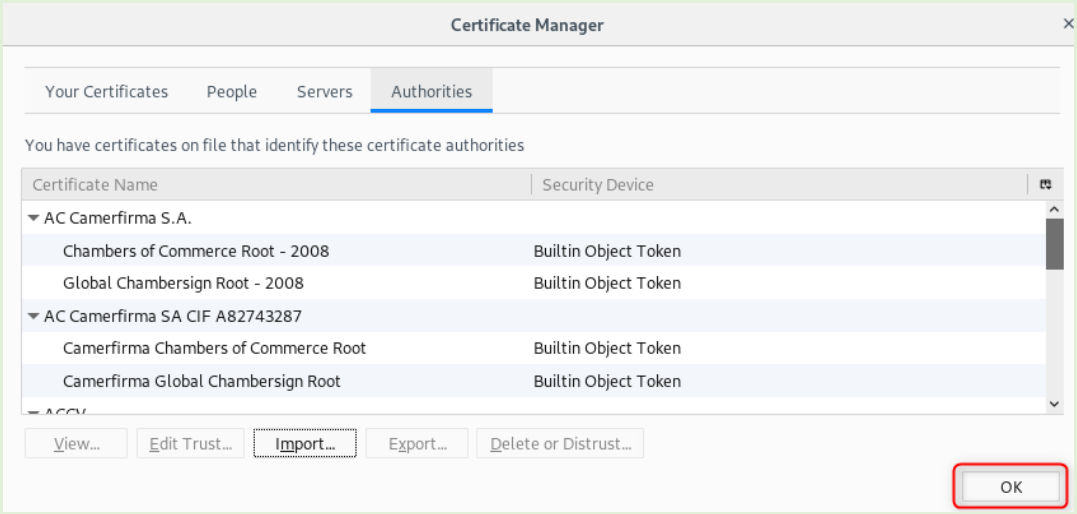
Load the certificate created earlier.



Select “Trust this CA to identify websites” and click OK.

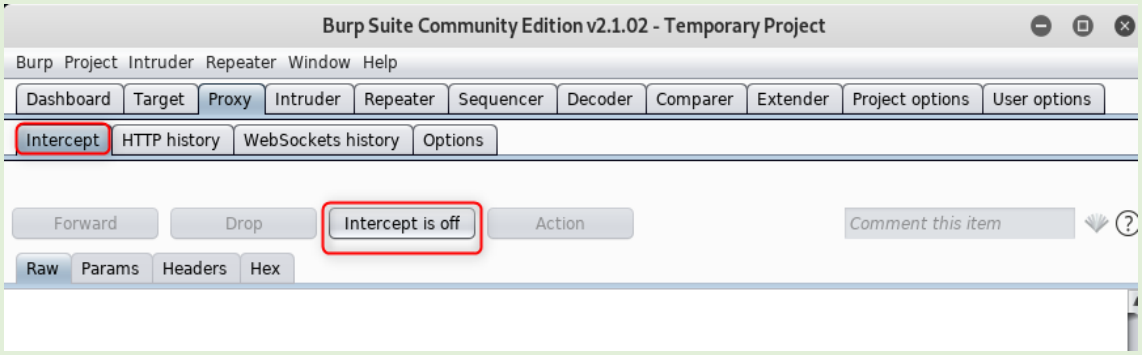


Click OK.

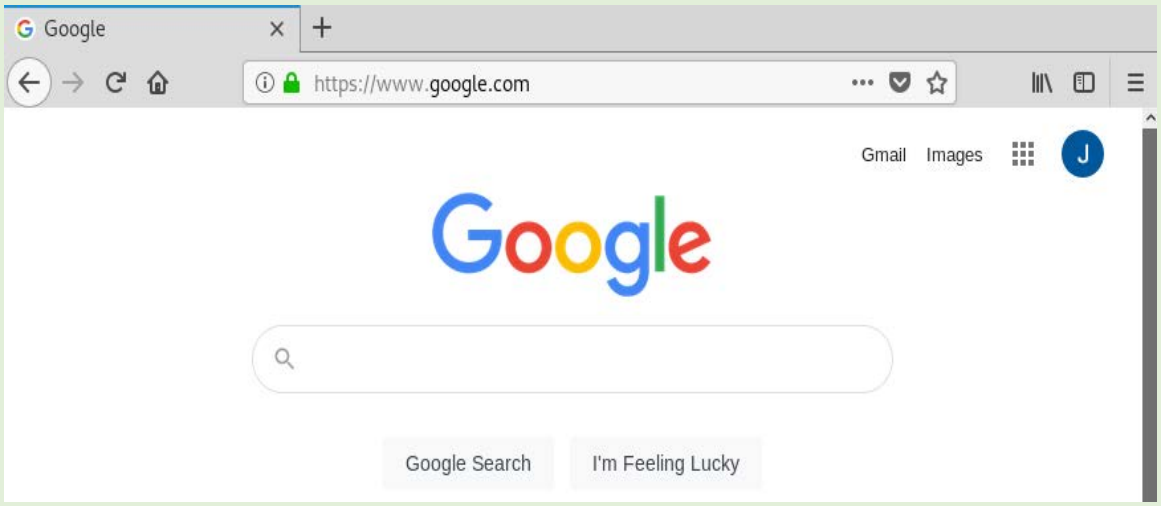


3 Turn off Interception in Burp Suite and browse Google.com again to verify that the warning no longer appears.

Switch back to the Burp Suite screen.
Make sure that you are in the Proxy tab, and click the Intercept option.
Select “Intercept is off”.



In the Firefox browser, browse to Google and note that no warning appears.

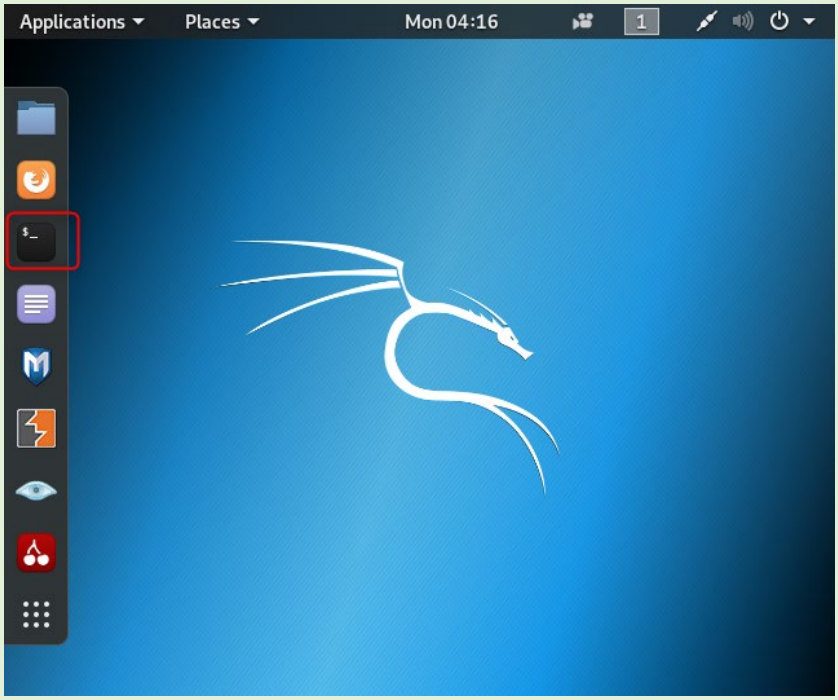


Lab Task 3: Hack Login Credentials

In this task, you will start an HTTP server with a website that asks for a password. The aim is to hack the password using Burp Suite.

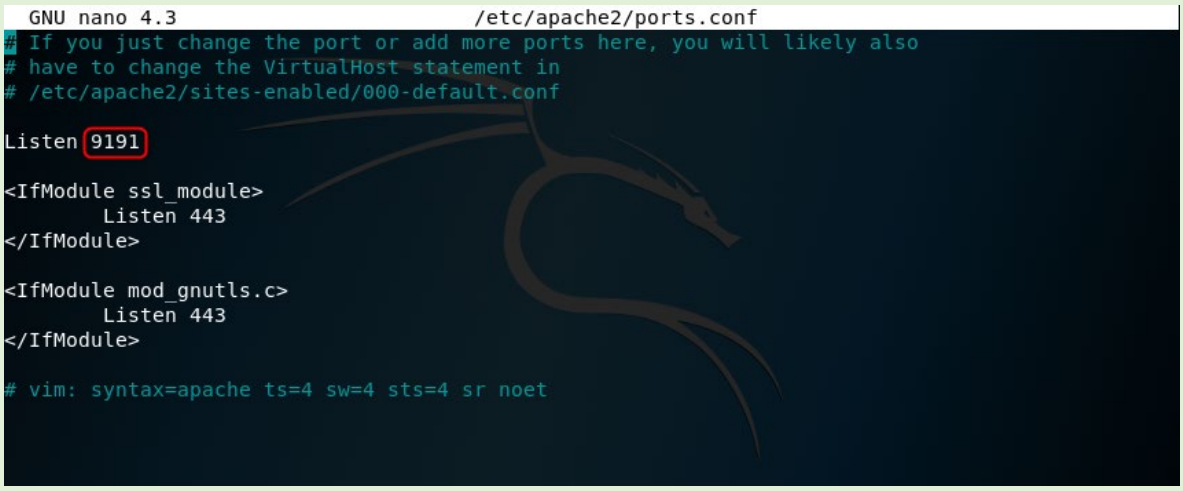
1 Set the apache2 port configuration to port 80, and restart the Apache2 service.

Start a terminal session by clicking the terminal icon in the menu bar.

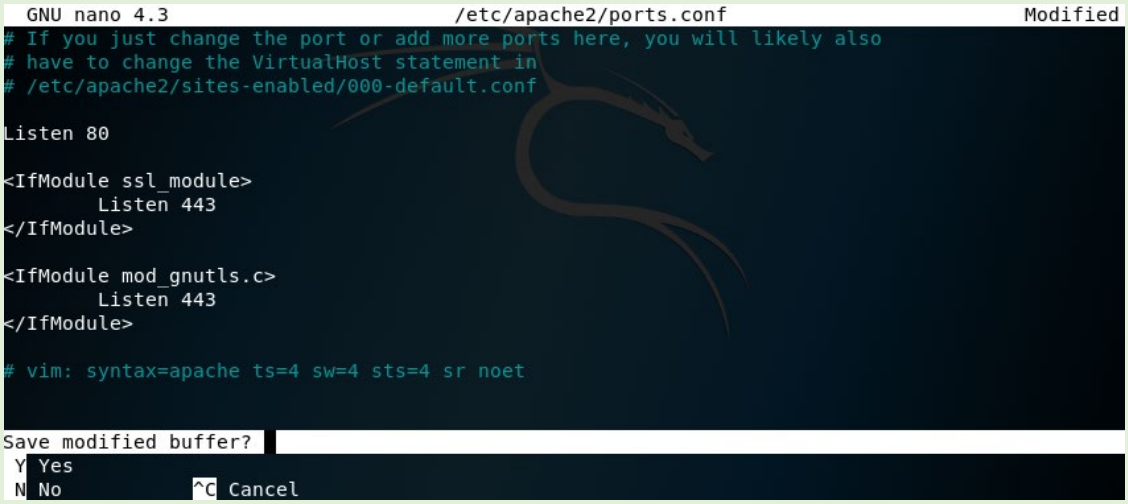


Type **nano /etc/apache2/ports.conf** to edit the configuration file.

```
root@kali:~# nano /etc/apache2/ports.conf
```



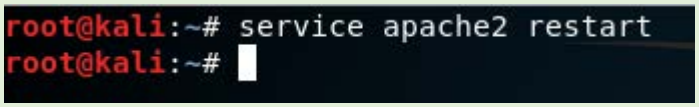
Use the arrows on the keyboard to scroll down, and change the listening port from 9191 to 80. Then press Ctrl+x and type 'y' to confirm the change.



Press Enter to finish and exit Edit mode.



Restart the apache2 service by typing **service apache2 restart**.



2 Back up the files in /var/www/html/ and replace them with the content of the provided WebPage directory.

In the terminal, move the files of /var/www/html to a backup location using:
mv /var/www/html/index.html /var/www/html/index.nginx-debian.html /root/Desktop
This will move the files to /root/Desktop.

```
root@kali:/# mv /var/www/html/index.html /var/www/html/index.nginx-debian.html /root/Desktop
root@kali:/#
```

Navigate to the location of the attached directory by typing **cd Desktop/WebPage/**

```
root@kali:~# cd Desktop/WebPage/
root@kali:~/Desktop/WebPage#
```

Use the ls command to display the content.

```
root@kali:~/Desktop/WebPage# ls
cred.php  image.jpg  index.html  WordList.txt
root@kali:~/Desktop/WebPage#
```

To move all files, type **mv * /var/www/html/**

```
root@kali:~/Desktop/WebPage# mv * /var/www/html/
root@kali:~/Desktop/WebPage#
```

Navigate to /var/www/html/ to verify that the correct files are there.
Type **cd /var/www/html/** to move to the directory.

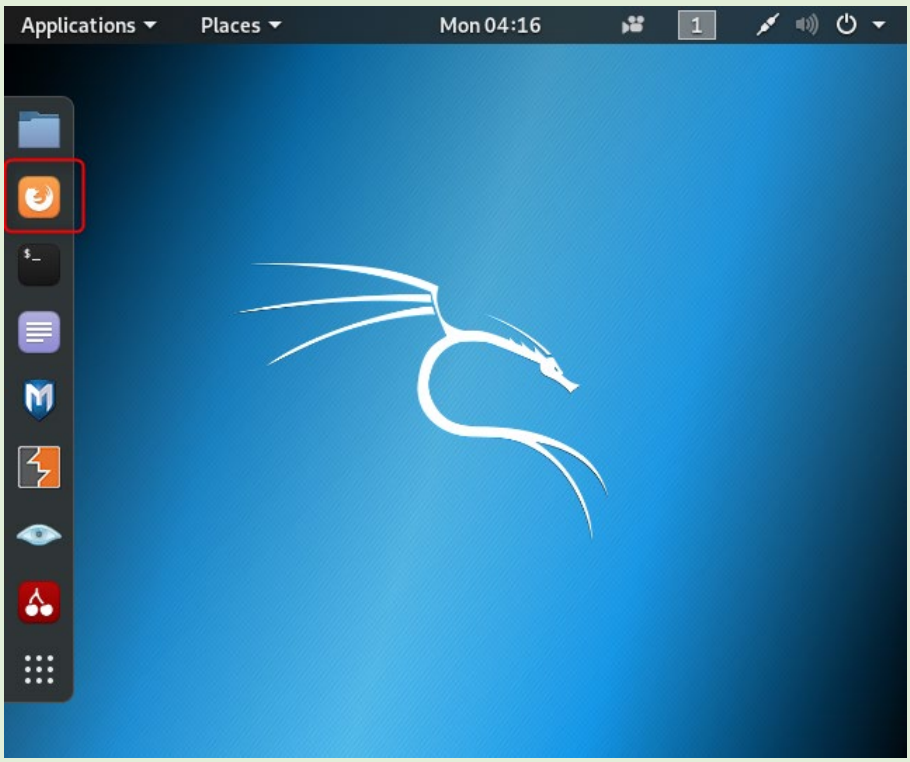
```
root@kali:~/Desktop/WebPage# cd /var/www/html/
root@kali:/var/www/html#
```

Use the ls command to display the content.

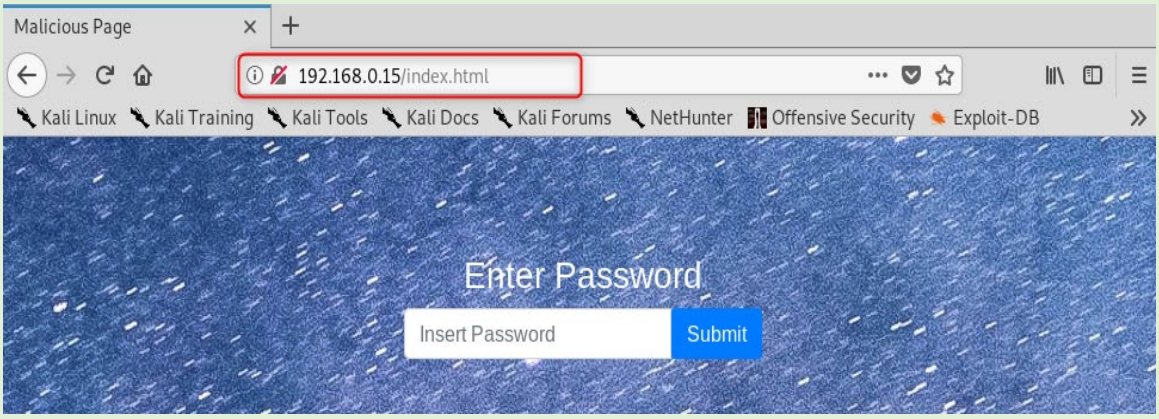
```
root@kali:/var/www/html# ls
cred.php  image.jpg  index.html  WordList.txt
root@kali:/var/www/html#
```

3 Browse to ***yourIP*/index.html** (use your IP address and not a loopback address, to enable Burp to intercept traffic). Try to guess the password, and note the message.

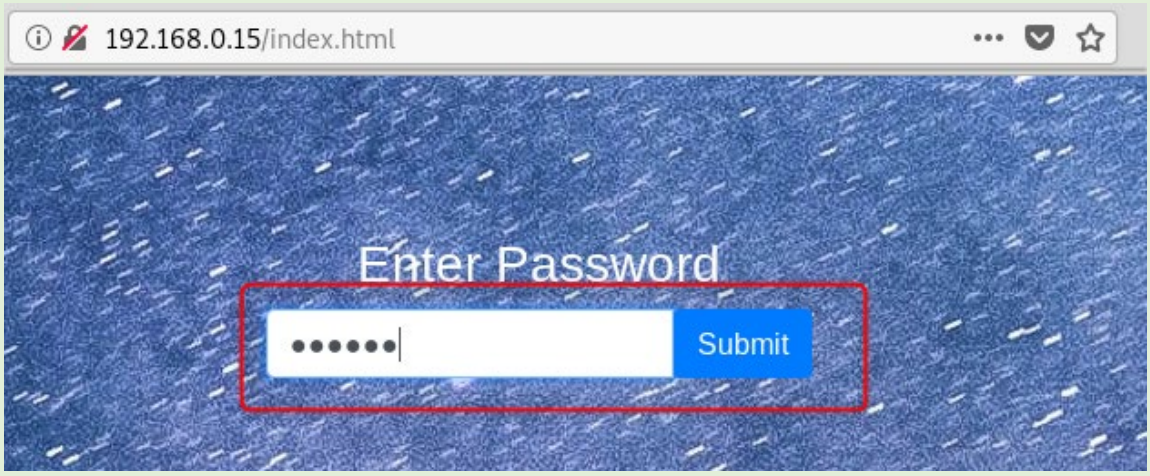
Open the browser by clicking the Firefox icon in the menu bar.



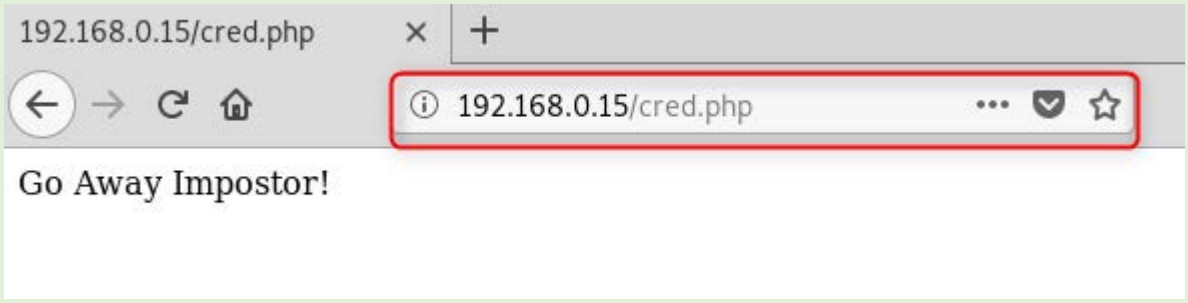
Type **192.168.0.15/index.html** in the URL address field to navigate to the web page.



Try any password and click Submit.

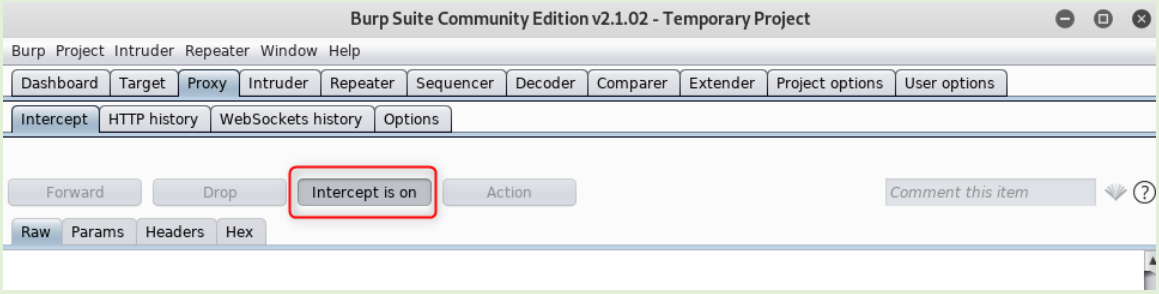


Note the result.

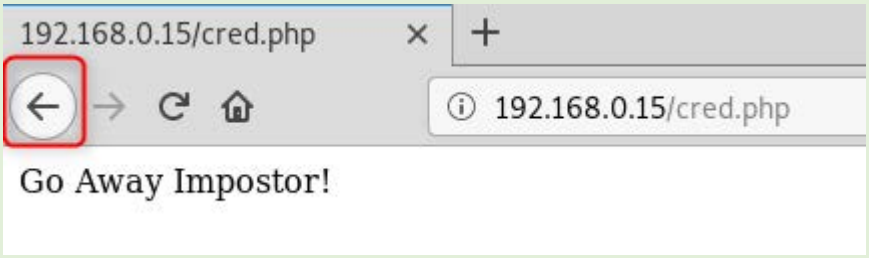


4 Start intercepting data with Burp Suite. Refresh the web page while intercepting, guess a password again, and examine the captured package.

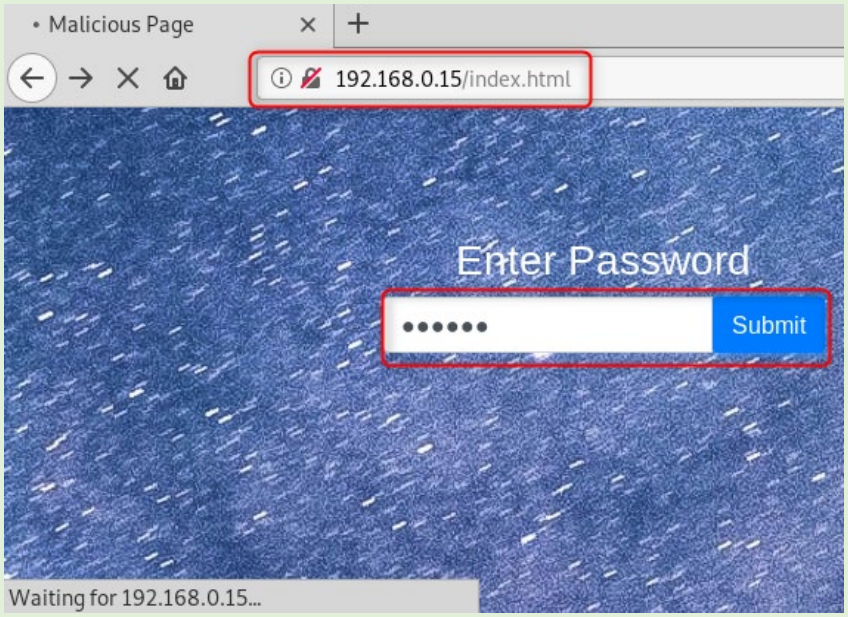
Switch to Burp Suite and turn on Intercept mode.



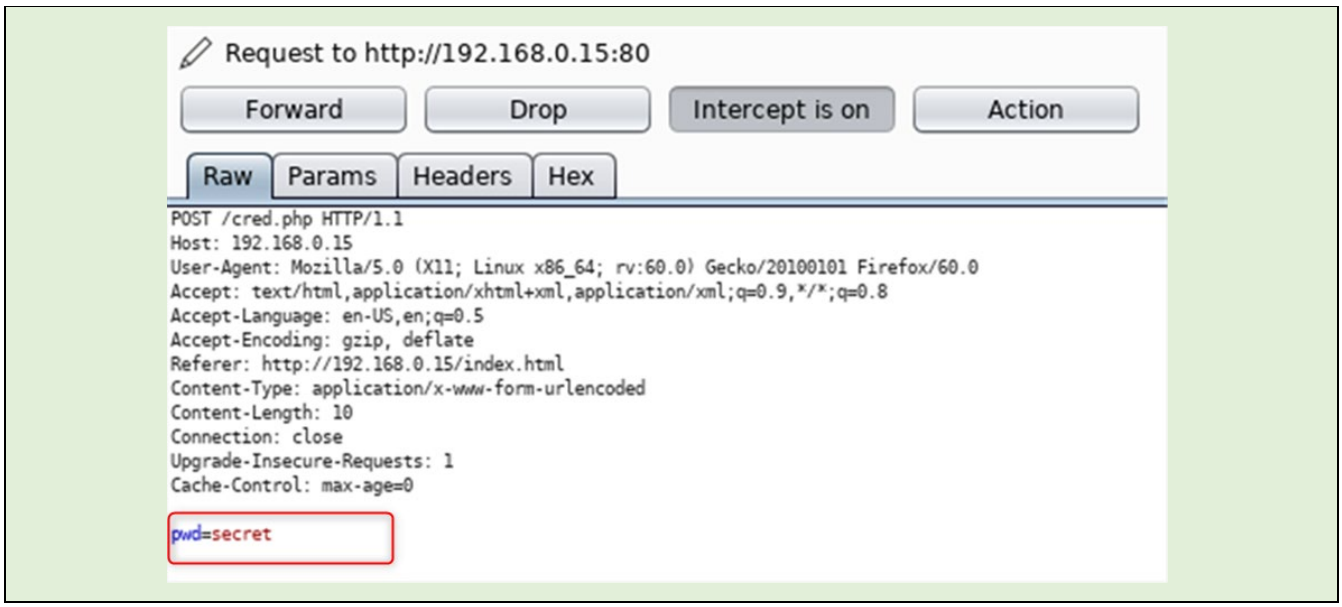
Switch back to Firefox and click the Go Back icon.



Enter a random password and click Submit.



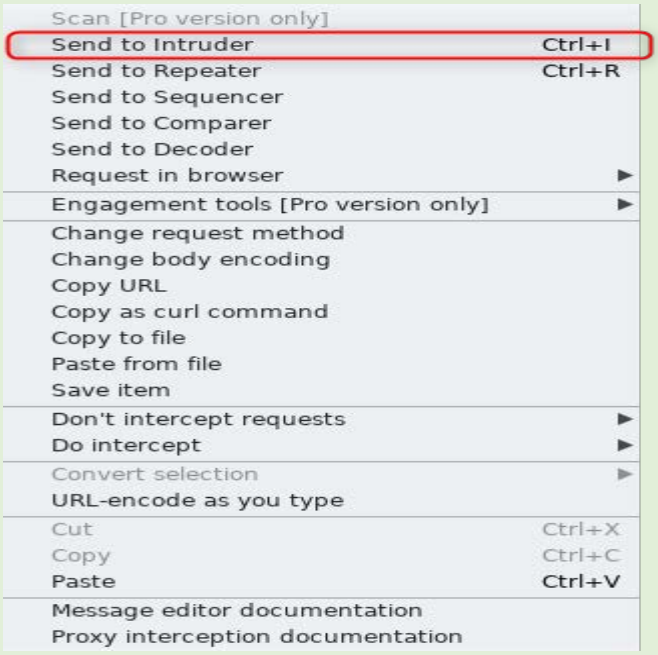
Intercept data with Burp Suite.



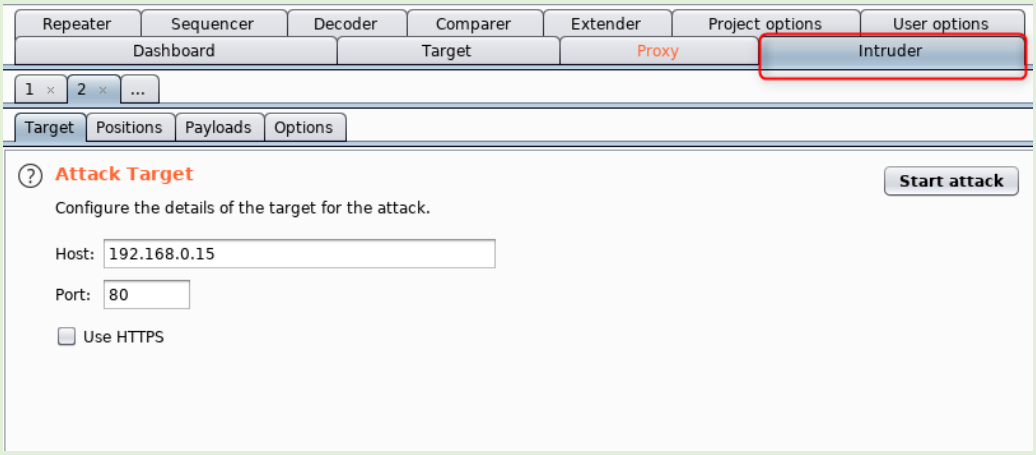
5 Select the Action tab and send the packet to the Intruder to begin a brute-force attack.



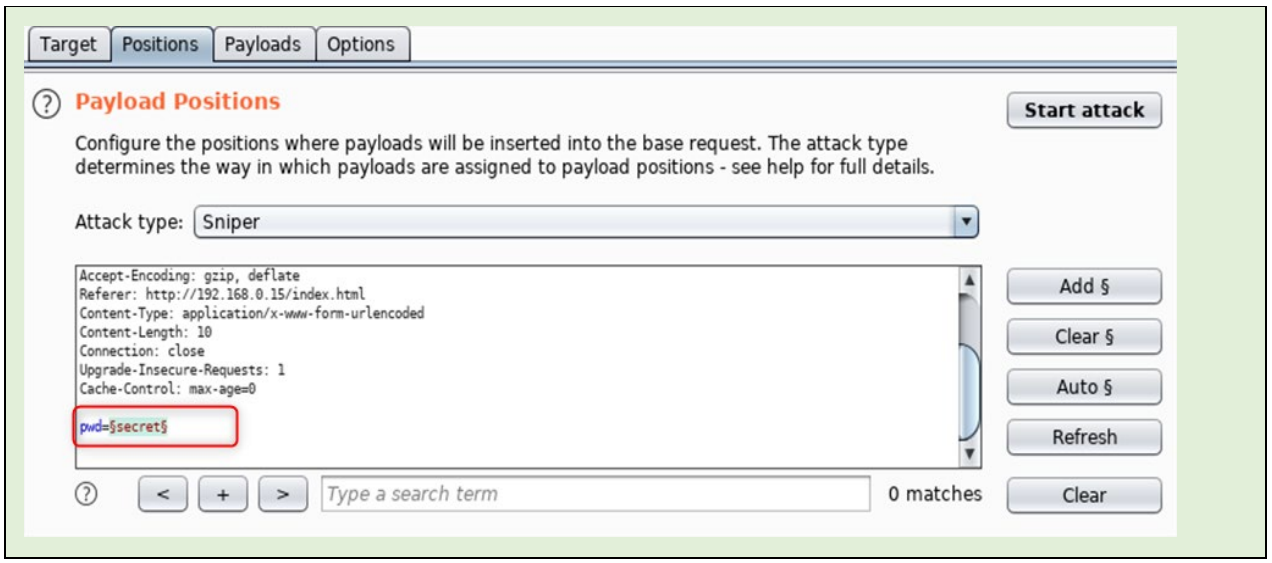
Select Send to Intruder.



Navigate to the Intruder tab to verify the target's details.

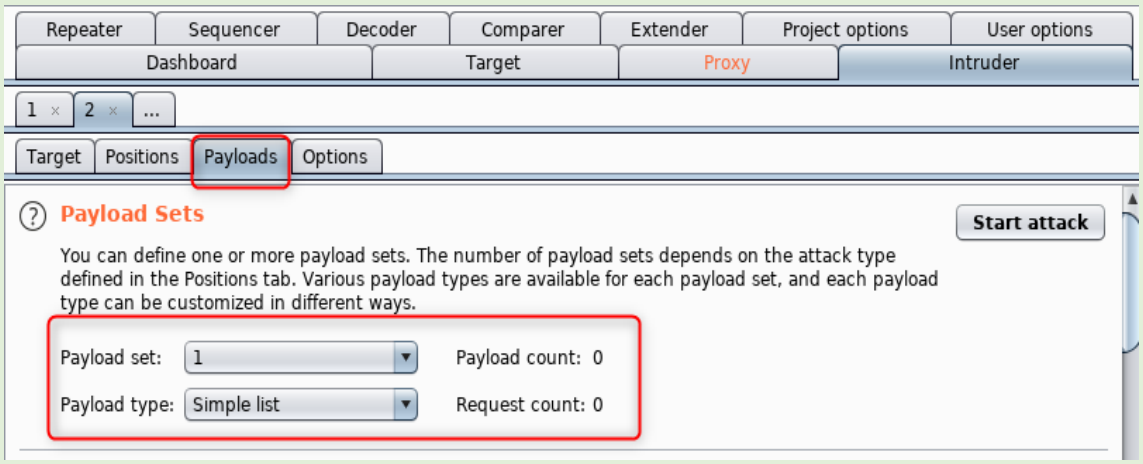


Navigate to the "Positions" tab and make sure the value of the Send parameter includes a character similar to $.
This tells Burp that the parameter should be substituted during the attack process.

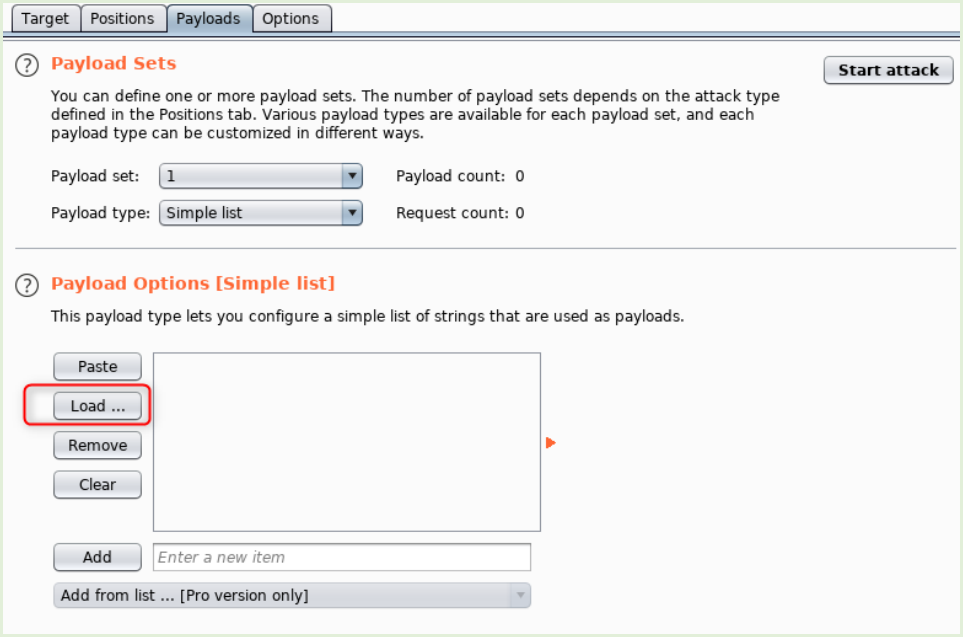


6 Load the WordList.txt file provided with this lab as the payload, and start the attack to detect the password.

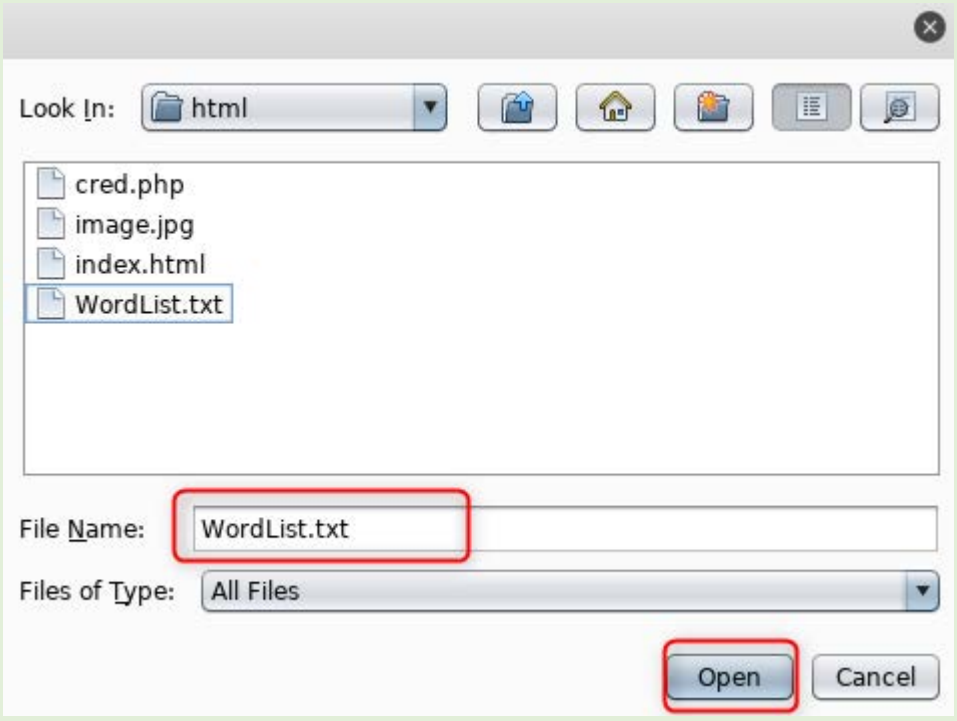
Navigate to the Payloads tab in Burp Suite.



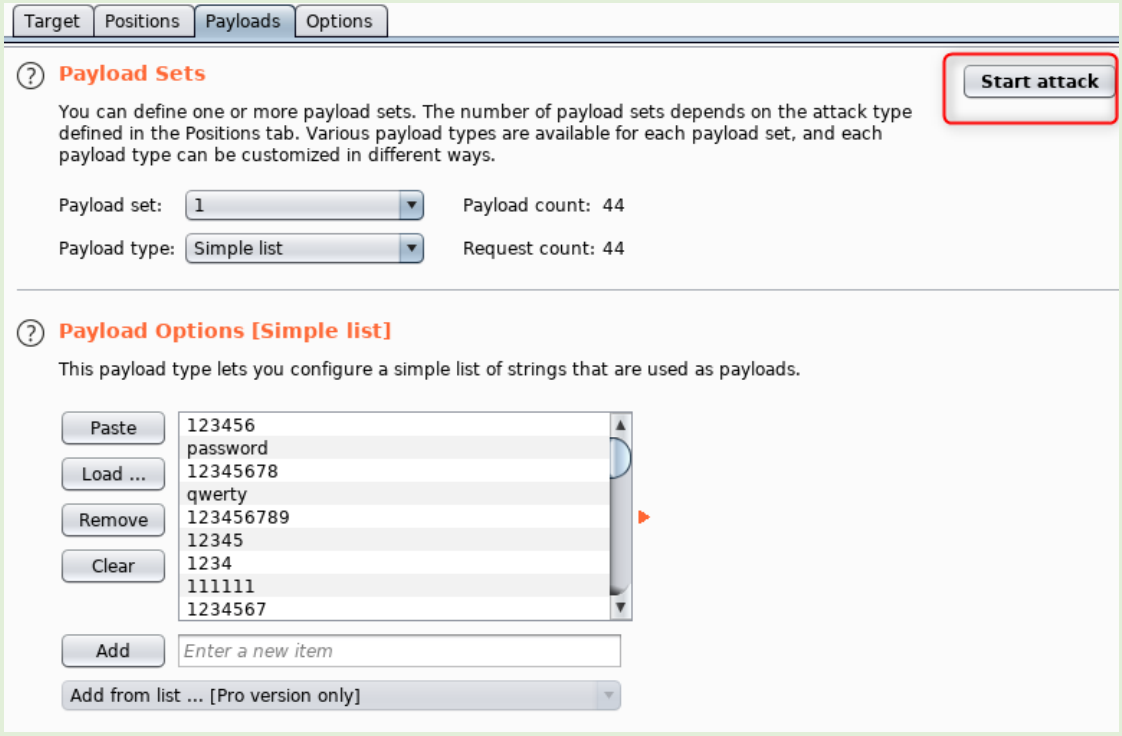
In the Simple List options, click Load.



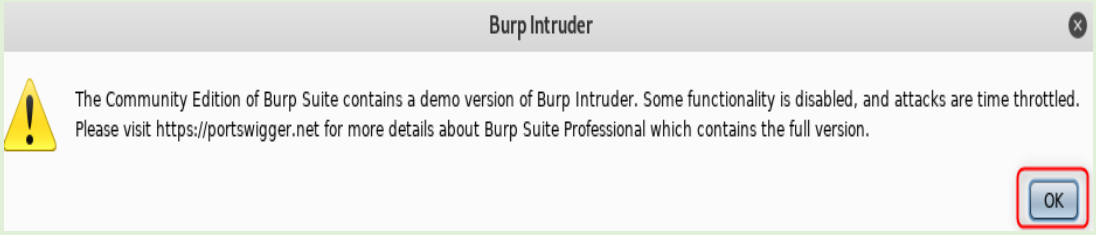
Load the Wordlist.txt file from /var/www/html.



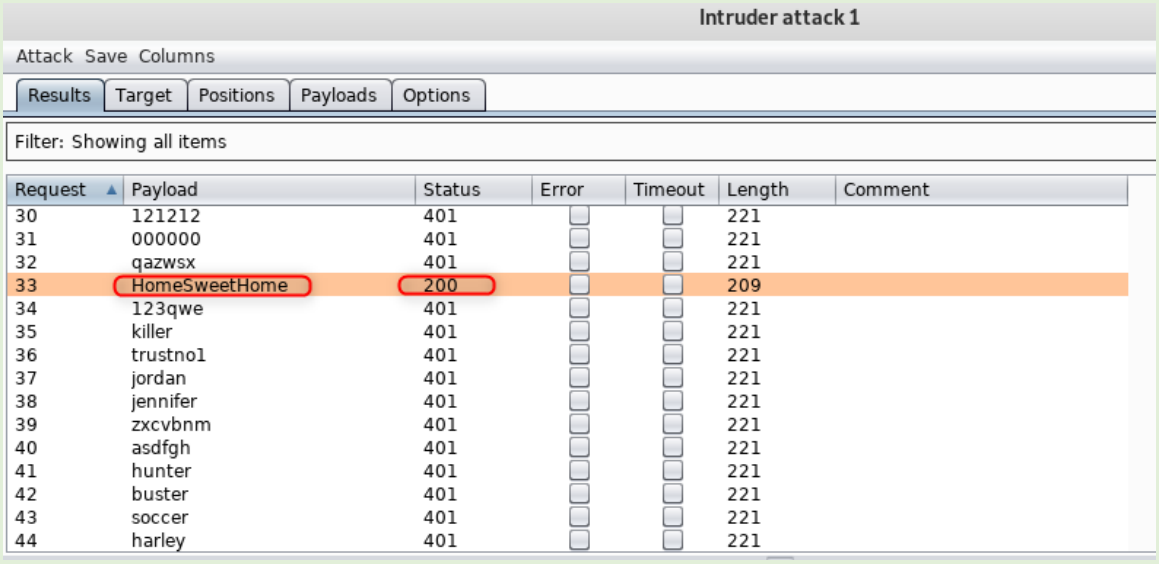
Click “Start attack”.



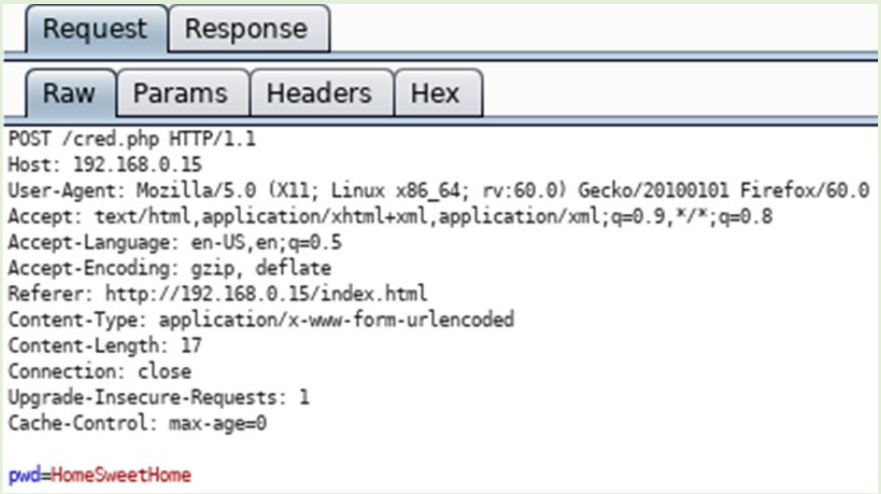
Ignore the warning and click OK.



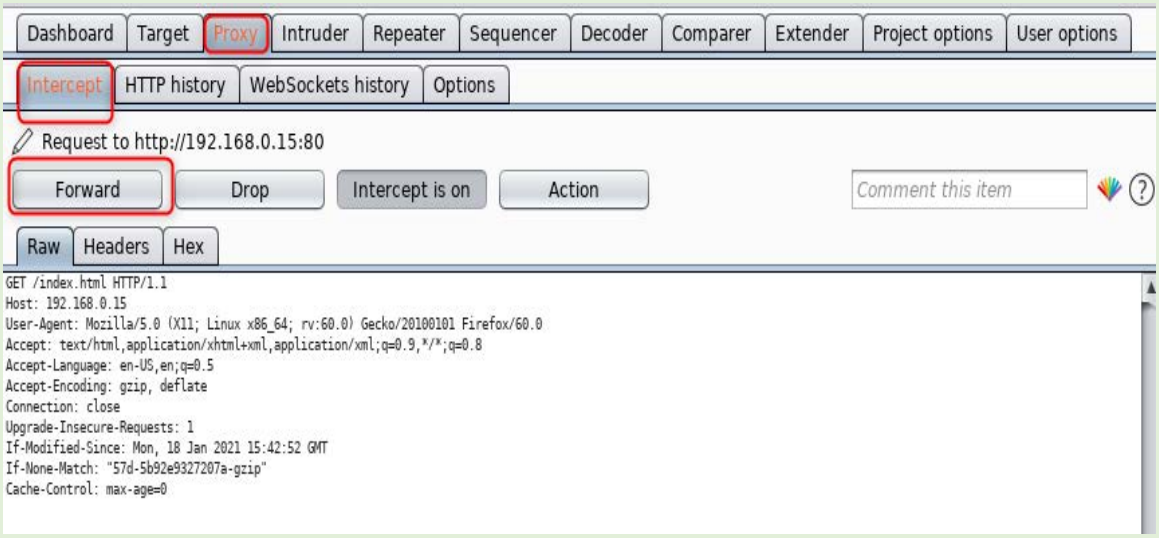
Identify the correct password for the connection with the status **200**.



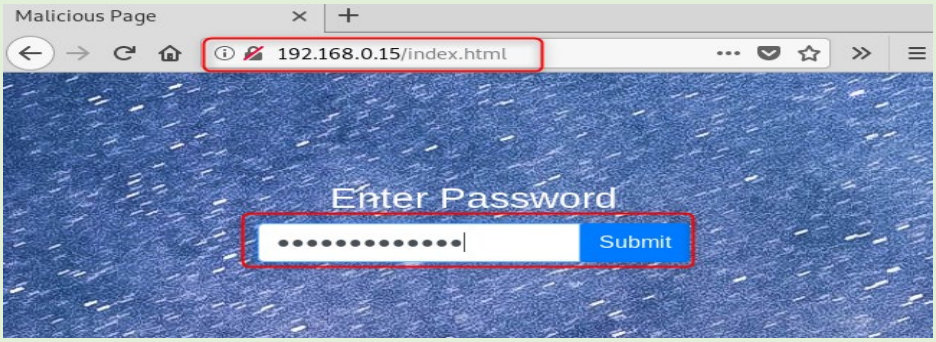
Request	Payload	Status	Error	Timeout	Length	Comment
30	121212	401			221	
31	000000	401			221	
32	qazwsx	401			221	
33	HomeSweetHome	200			209	
34	123qwe	401			221	
35	killer	401			221	
36	trustno1	401			221	
37	jordan	401			221	
38	jennifer	401			221	
39	zxcvbnm	401			221	
40	asdfgh	401			221	
41	hunter	401			221	
42	buster	401			221	
43	soccer	401			221	
44	harley	401			221	



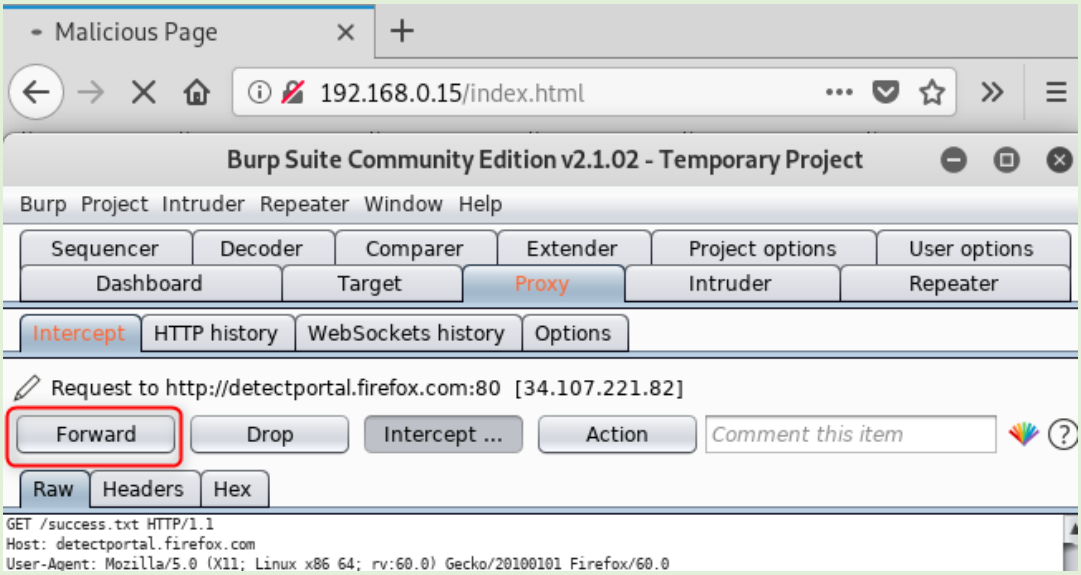
The correct password returns an HTTP response header with code 200 instead of 401.
The correct password is “HomeSweetHome”.
Use the correct password to log in to the website.
Switch to the Proxy tab and select intercept mode options. Forward everything to refresh the web site.



Type **HomeSweetHome** in the password field and click Submit.



Switch again to Burp Suite and click Forward.



Enter the website and examine the results.

